

PULSE Instrument Cluster

Cybersecurity Concept, preliminary (ISO/SAE 21434, UNECE R155)

Ahmed Abdelghany

2026-09-23

Contents

Document control	1
Change log	1
1. Purpose and proportionality	2
2. Item and trust boundaries (CS-2)	2
3. Assets	3
4. Preliminary threat analysis and risk assessment (CS-1)	3
5. Controls and the development-configuration deviations	5
6. Update concept (CS-10)	6
7. Cybersecurity requirements	6
8. Verification in the regression suite (CS-11)	8

Document control

Field	Value
Document ID	PULSE-SEC-001
Title	Cybersecurity Concept, preliminary
Version	0.9.5
Status	Skeleton for sprint 1 review; not security-reviewed
Date	2026-10-02
Author	Ahmed Abdelghany
Reviewer	Security manager, not yet assigned
Review gate	Sprint 1 review for structure; sprint 2 review for content
Parent	PULSE-SyRS-001
Related	PULSE-StRS-001, PULSE-SAD-001, PULSE-SAF-001, PULSE-RTM-001

Change log

Version	Date	Author	Change
0.9	2026-09-03	A. Abdelghany	First skeleton: item and trust boundaries, assets, preliminary TARA, controls, development-configuration deviations, update concept outline, CS-1 to CS-11 with status
0.9.1	2026-09-03	A. Abdelghany	Threat map and update-flow diagrams added; trust-boundary diagram moved to draw.io

Version	Date	Author	Change
0.9.2	2026-09-03	A. Abdelghany	CS-9 and CS-11 status updated for the regression suite
0.9.3	2026-09-08	A. Abdelghany	Section 8 check list turned into a table. CS-1 and CS-10 reworded. CS-8, the asset table and threat T-6 updated: the broker image is pinned, so only the SBOM gap remains. Glossary pointer added
0.9.4	2026-09-23	A. Abdelghany	Sprint 2 controls landed: TLS and token authorisation (CS-3, CS-4), HMI-side range check (CS-5), SBOM with OSV scan (CS-8), privacy trace (CS-6), CI (CS-11). Deviation from mutual TLS recorded in section 5
0.9.5	2026-10-02	A. Abdelghany	CS-6 to Implemented after its first real run. Finding recorded in section 5: MediaPipe's built-in usage logger, held on the host. CS-8 extended to the full resolved Python set (constraints.txt)

1. Purpose and proportionality

The stack is a broker on an internal network with two consumers, two providers and one camera-based sensor. The security work is proportionate to that. The goal is the same as for safety: produce the artefacts a programme would need under ISO/SAE 21434 and UNECE R155, and remove the shortcuts that only exist because this runs on a desk.

Nothing in this document has been reviewed by a security manager. Ratings are the project engineer's proposals.

Abbreviations used here are defined in the glossary, PULSE-StRS-001 section 8.

2. Item and trust boundaries (CS-2)

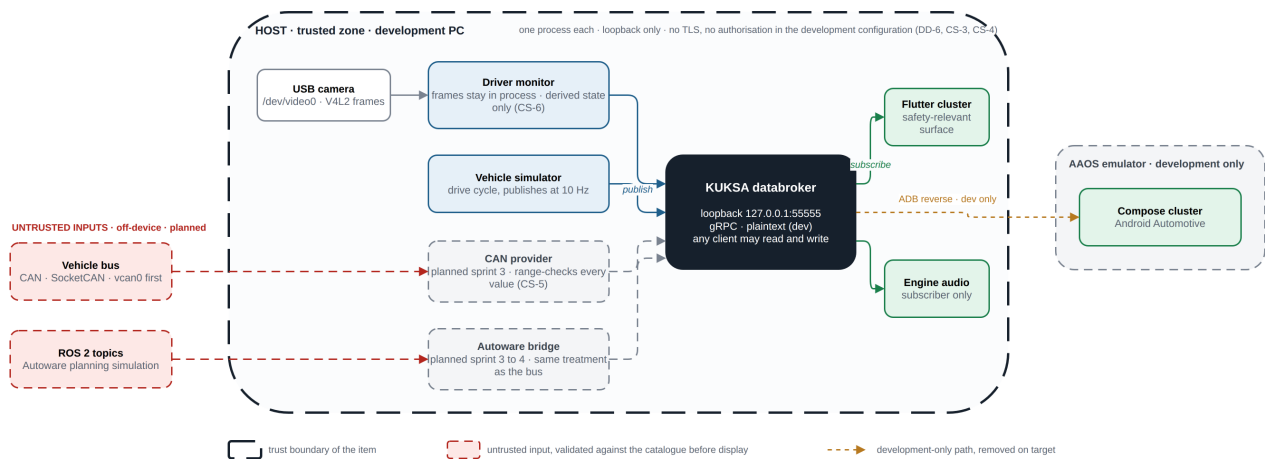


Figure 1: Item and trust boundaries in the development configuration, with the planned untrusted inputs.

Source: docs/diagrams/pulse-trust-boundaries.drawio (edit in draw.io, re-export with scripts/build-docs.sh).

Boundary	On-device or off-device	Trust today	Trust target
Broker gRPC endpoint	On-device, loopback only	Anyone on the host can read and write	Mutual TLS, per-client write authorisation (CS-3, CS-4)

Boundary	On-device or off-device	Trust today	Trust target
Camera	On-device	Trusted input; frames stay in process	Same; add tamper and covering detection as backlog
Vehicle bus	Off-device (planned)	Not present	Untrusted; every decoded value range-checked (CS-5)
Autonomy stack	Off-device (planned)	Not present	Untrusted; same treatment as the bus
ADB reverse to the emulator	Development only	Trusted	Removed on target; the Android surface reaches the broker over an authenticated channel
Container image registry	Off-device	Pinned to the 0.7.0 tag and digest	Signature verification (CS-8)

3. Assets

Asset	Property to protect	Damage scenario
Safety-relevant signals (speed, gear, alert, intervention)	Integrity, availability	Driver misled; unintended manoeuvre
Signal catalogue (vss_agl.json)	Integrity	Broker serves a tampered tree; range checks bypassed
Camera frames	Confidentiality	Driver surveillance; privacy breach
Driver-state signals	Confidentiality, integrity	Personal data leakage; spoofed drowsiness
Broker configuration and credentials	Confidentiality, integrity	Unauthorised control of the signal path
Software artefacts (bundle, APK, container image)	Integrity, authenticity	Malicious update
Third-party dependencies	Integrity	Supply-chain compromise

4. Preliminary threat analysis and risk assessment (CS-1)

Attack feasibility per ISO/SAE 21434 annex: high, medium, low, very low. Impact: severe, major, moderate, negligible. Risk 1 to 5 from the standard's matrix.

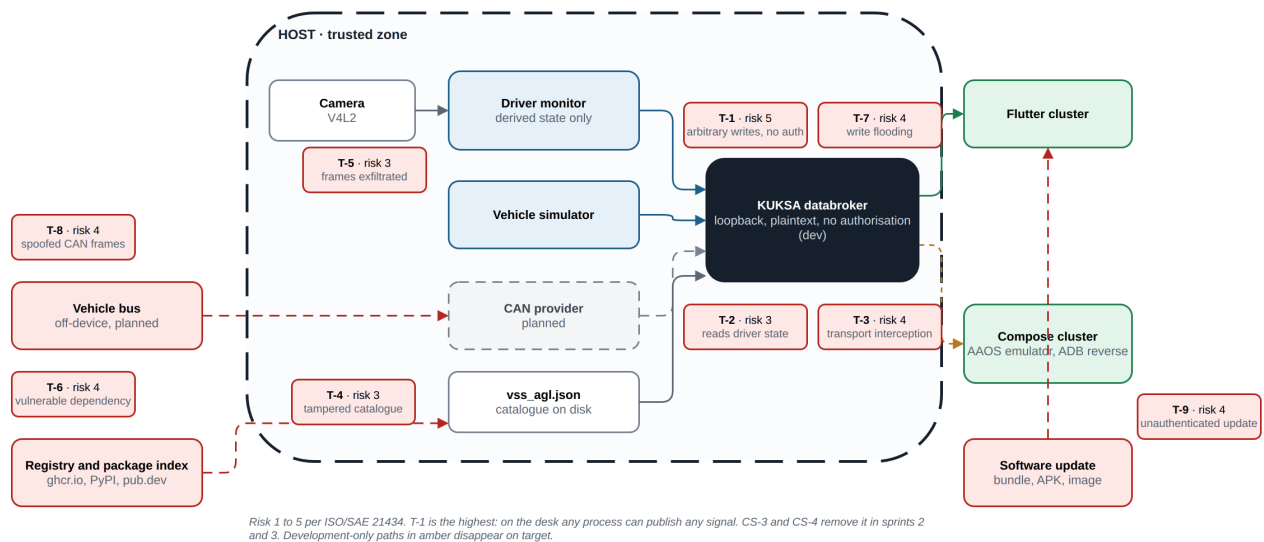


Figure 2: The nine threat scenarios placed on the architecture, with their risk values.

Source: docs/diagrams/tara-map.drawio.

ID	Threat scenario	Asset	Feasibility today	Impact	Risk	Treatment
T-1	A process on the host publishes arbitrary values for speed or alert state to the broker	Safety-relevant signals	High (no authentication, no authorisation)	Severe	5	CS-3, CS-4: authenticate clients, authorise writes per client
T-2	A process on the host subscribes to driver-state signals	Driver-state signals	High	Moderate	3	CS-3: authenticated transport; read scoping is backlog
T-3	Interception or modification of gRPC traffic	Signals	Low on loopback; high once off-device	Severe	4 at target	CS-3: mutual TLS before any off-device client
T-4	Tampered signal catalogue mounted into the broker	Catalogue	Medium (file on disk, read-only mount)	Major	3	CS-8, CS-9: catalogue checksum in the regression suite; FR-3 reproducibility
T-5	Camera frames exfiltrated or persisted by a modified driver monitor	Camera frames	Low	Severe (privacy)	3	CS-6: code review and a test that no file is written; process has no network beyond loopback
T-6	Malicious or vulnerable dependency (Python package, Dart package, container image)	Dependencies	Medium (no SBOM)	Major	4	CS-8: pinned digests, SBOM, vulnerability check
T-7	Flooding the broker with writes to starve subscribers	Availability	High	Major	4	CS-4 limits writers; rate limiting is backlog; staleness detection (SR-4) keeps the display honest

ID	Threat scenario	Asset	Feasibility today	Impact	Risk	Treatment
T-8	Spoofed CAN frames on the bus once the CAN provider exists	Safety-relevant signals	Medium on a physical bus	Severe	4	CS-5: range and plausibility checks; bus-level security is outside the item
T-9	Unauthenticated software update replaces the cluster bundle	Artefacts	Medium	Severe	4	CS-10: signed packages, rollback on failure

5. Controls and the development-configuration deviations

Control	Requirement	State today	Removal of the shortcut
Transport encryption and client authentication	CS-3	TLS to a development certificate; every client presents a signed token. Plaintext only on request, with a warning (DD-6 closed)	Sprint 2: enable TLS in the databroker with development certificates under certs/dev/ marked non-production; start-up prints a red warning whenever --insecure is used
Per-client write authorisation	CS-4	Token scopes: consumers read only, providers limited to their own signals	Sprint 3: KUKSA JWT authorisation with one token per provider scoped to its signal set; consumers get read-only tokens
Catalogue validation of incoming values	CS-5	Broker rejects on set; both HMIs refuse out-of-restriction values as defence in depth	Sprint 2: HMI-side check as defence in depth; test that an out-of-range publish is refused
Camera data stays local	CS-6	Driver monitor never writes frames and publishes derived state only; MediaPipe's usage logger is held on the host; dms-privacy proves both	Sprint 2: test asserting no file output and no socket other than the broker
Security event logging	CS-7	None	Sprint 3: broker and provider logs for authentication failure, refused write, client disconnect; timestamped; no personal data
Dependency pinning and SBOM	CS-8	Everything pinned, the full Python set through constraints.txt; CycloneDX SBOM in docs/sbom/, scanned against OSV by the suite	Sprint 2: pin the image digest; generate a CycloneDX SBOM per component; run a vulnerability check in the regression suite
No secrets in the repository	CS-9	Development PKI generated into git-ignored .run/pki/; suite scans every tracked file	Sprint 2: secret scan in the regression suite; development certificates clearly named and gitignored where private
Update concept	CS-10	None	Sprint 4: section 6 completed

Finding: usage telemetry inside a dependency (T-5, T-6). The first run of dms-privacy with the driver monitor executing, on 2 October, found that the process resolved play.googleapis.com and opened HTTPS connections to it. The source is MediaPipe itself: in 0.10.35 and 1.0.1, the versions tested, every task runner starts a libcurl client that posts session statistics (task type, timings) to Google. No camera frame or derived driver state is in those reports, but CS-6 says no socket except the broker, and the library offers no switch to turn the logger off. The driver

monitor therefore sets the proxy variables, which libcurl honours, to a closed local port before MediaPipe loads, and exempts the broker through NO_PROXY, which gRPC also honours. The trace shows the logger's attempts ending on the host and the broker connection unchanged. This is a workaround, not a configuration option: a MediaPipe upgrade must be re-checked by the suite, and a production target would enforce the same rule at the platform level (for example a per-service network policy that allows loopback only). The finding also shows why the check must run where the monitor runs: on the reference VM it had only ever skipped.

Deviation from CS-3 as written. CS-3 names mutual TLS. KUKSA databroker 0.7.0 can present a server certificate but cannot verify client certificates; it has no option for a client CA. Clients are therefore authenticated by a signed token carried over the TLS session, which the broker verifies against `jwt.pem`. The security goal, that only known clients reach the broker and that the link is encrypted and server-authenticated, is met; the mechanism is not the one the requirement names. Either the requirement text is changed at the sprint 2 review, or a broker with client-certificate support is adopted later. Recorded as DD-12 in PULSE-SAD-001.

6. Update concept (CS-10)

Outline, to be completed in sprint 4. UNECE R155 and R156 make this a type-approval matter, so the concept is written now and executed later.

UNECE R155 and R156 make package authenticity and failed-update behaviour a type-approval matter. Cluster, driver monitor and broker configuration form one software identification unit (RXSWIN).

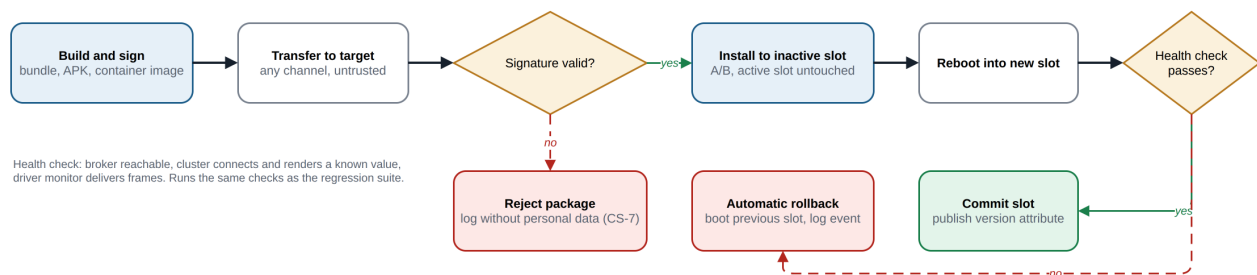


Figure 3: Update concept: signed package, A/B slot install, health check, automatic rollback.

Source: docs/diagrams/update-flow.drawio.

- Package authenticity: every deliverable (Linux bundle, APK, container image) is signed; the target verifies the signature before installation.
- Version identification: the cluster displays and publishes its software version as a VSS attribute so a fleet can be audited.
- Failed update: A/B slots on the Linux target; a failed boot after update reverts to the previous slot automatically; the Android side relies on the platform's own A/B mechanism.
- Scope of RXSWIN: the cluster, driver monitor and broker configuration form one software identification unit for R156 purposes.

7. Cybersecurity requirements

ID	Requirement	VerificationStatus (W3)		Evidence
CS-1	A threat analysis and risk assessment (TARA) shall be recorded for the signal path, covering the broker, both HMI clients, the telemetry provider and the camera input. Each threat scenario shall carry an attack feasibility rating, as ISO/SAE 21434 clause 15 requires.	I	Partial	Section 4, nine scenarios
CS-2	The item boundary and its trust boundaries shall be documented, distinguishing on-device interfaces from anything reachable off the device.	I	Implemented	Section 2
CS-3	Broker communication shall support authenticated, encrypted transport (mutual TLS). Running without it shall be a configuration reserved for local development and flagged at start-up.	T	Implemented	TLS with a development certificate and a signed token per client, secure by default in scripts/start-databroker.sh; plaintext only with PULSE_INSECURE=1 and a boxed warning. Suite check transport-security. Deviation: token authentication rather than client certificates, section 5
CS-4	Write access to the signal tree shall be authorised per client. A consumer shall not be able to publish, and no client shall write outside its declared signal set.	T	Implemented	Token scopes from scripts/dev_pki.py: consumers read only; each provider may provide only the signals its source declares. Suite check transport-security proves a consumer cannot publish and a provider is refused outside its set
CS-5	Signal values received from any provider shall be range- and type-validated against the catalogue before display, so a compromised provider cannot drive arbitrary content onto the cluster.	T	Implemented	Broker refuses out-of-catalogue values (suite check range-refusal); both HMIs read the catalogue restrictions from the broker at connect and refuse values outside them, tested in range_check_test.dart and FreshnessTest.kt
CS-6	Camera frames shall not leave the device and shall not be persisted. Only derived state, such as the drowsiness level, shall be published.	I	Implemented	emulator/dms.py publishes six derived signals. Suite check dms-privacy traces every file and socket call for 12 s. Its first run with the monitor actually executing (2 October, a host with AVX) found the MediaPipe usage logger described in section 5; with that held on the host the check passes: no file left behind, no socket except the broker

ID	Requirement	Verification	Status (W3)	Evidence
CS-7	Security-relevant events, including authentication failure, unauthorised write attempt and client disconnection, shall be logged with a timestamp and without personal data.	T	Planned S3	Section 5
CS-8	All third-party dependencies shall be pinned and inventoried as a software bill of materials, and the inventory shall be checkable against published vulnerabilities.	T	Implemented	scripts/sbom.py writes a CycloneDX inventory of 85 components across Python, Dart, Android and the broker image; suite check sbom fails on drift or on any OSV advisory. First run found 36 Pillow advisories, fixed by moving to Python 3.11 and Pillow 12.3
CS-9	No credential, key or certificate shall be committed to the repository; the development configuration shall use clearly marked non-production material.	T	Implemented	Suite check secrets; the development CA, keys and tokens are generated into git-ignored .run/pki/ with NOT FOR PRODUCTION in every subject, never committed
CS-10	An update concept shall be described for the cluster and monitor software. It shall cover package authenticity and the behaviour on a failed update, as UNECE R155 and R156 require for type approval.	I	Planned S4	Section 6 outline
CS-11	Cybersecurity requirements shall be verified as part of the sprint regression suite, not as a separate end-of-project activity.	T	Implemented	16-check suite in scripts/regression.sh, run before each demo and on every push by .github/workflows/regression.yml; each check names the requirements it evidences

8. Verification in the regression suite (CS-11)

From sprint 2 the regression suite runs before every demo. It carries these checks:

Check	What it asserts	Covers
Catalogue checksum	The compiled signal tree is the one that was reviewed	T-4
Range check	The broker refuses a publish outside the catalogue range	CS-5
Monitor isolation	The driver monitor writes no file and opens no socket except the broker	CS-6
Dependency scan	No component has a known vulnerability, checked against the SBOM	CS-8
Secret scan	No key or credential appears in any tracked file	CS-9
Plaintext refusal	The broker refuses an unencrypted or tokenless client; a consumer cannot publish; a provider cannot publish outside its own signals (transport-security)	CS-3, CS-4, IR-5

Check	What it asserts	Covers
Toolchain pin Live contract	The Flutter SDK in use is the pinned one (toolchain-pin) Every catalogue path in appendix A delivers a correctly typed datapoint from the running broker (live-contract)	NFR-8 FR-11, FR-13, IR-2